Welcome to Code Crunch!

C[6] | [CYBER CRUNCH: Web Security]

[Thu 1-2PM] Weekly | Spring 2025

Attendance

linktr.ee/CODE.CRUNCH

Understanding Web Security

What is Web Security?

- Web security protects websites and web applications from cyber threats, unauthorized access, and data breaches. Without proper security measures, attackers can exploit vulnerabilities to steal sensitive information, compromise accounts, and disrupt services.

Why It Matters (Real-World Examples)

Equifax Data Breach (2017) – Poor input validation allowed attackers to exploit an unpatched vulnerability, exposing personal data of 147 million people.
Facebook Data Leak (2019) – Weak authentication led to the exposure of 540 million user records on a public server.
Yahoo Hacks (2013-2014) – Stolen credentials from weak security practices resulted in breaches affecting 3 billion accounts.

Key Concepts in Web Security

- ✔ **HTTPS Encryption** – Protects data in transit, preventing interception (Man-in-the-Middle attacks).
  ✔ **Input Validation** – Blocks malicious code injections like SQL Injection and Cross-Site Scripting (XSS).
  ✔ **Authentication & Authorization** – Ensures only legitimate users can access systems and prevents privilege escalation attacks.

Understanding Web Security

What is Web Security?

- Web security protects websites and web applications from cyber threats, unauthorized access, and data breaches. Without proper security measures, attackers can exploit vulnerabilities to steal sensitive information, compromise accounts, and disrupt services.

Why It Matters (Real-World Examples)

Equifax Data Breach (2017) – Poor input validation allowed attackers to exploit an unpatched vulnerability, exposing personal data of 147 million people.
Facebook Data Leak (2019) – Weak authentication led to the exposure of 540 million user records on a public server.
Yahoo Hacks (2013-2014) – Stolen credentials from weak security practices resulted in breaches affecting 3 billion accounts.

Key Concepts in Web Security

- ✔ **HTTPS Encryption** – Protects data in transit, preventing interception (Man-in-the-Middle attacks).
  ✔ **Input Validation** – Blocks malicious code injections like SQL Injection and Cross-Site Scripting (XSS).
  ✔ **Authentication & Authorization** – Ensures only legitimate users can access systems and prevents privilege escalation attacks.

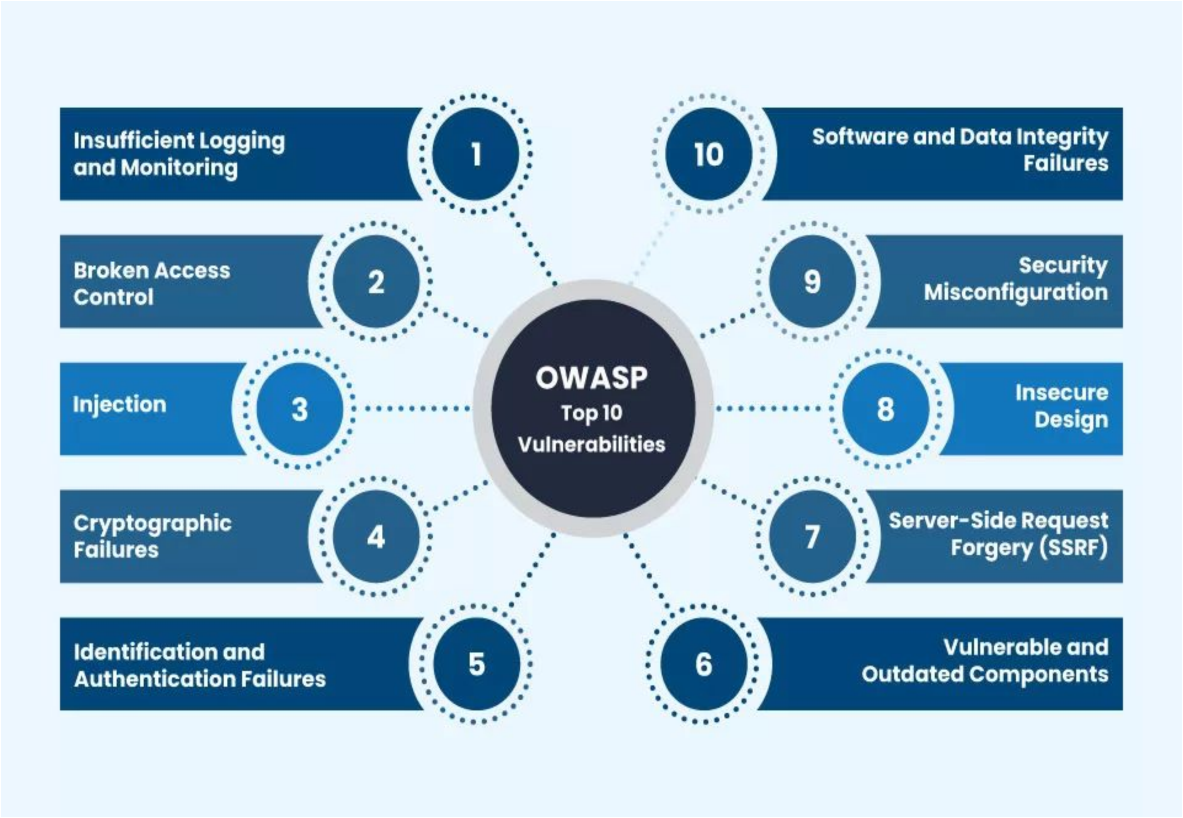
Common Web Vulnerabilities

- **Injection Attacks:** SQL injection, Command injection.
- **Cross-Site Scripting (XSS):** Malicious scripts executed in user browsers.
- **Cross-Site Request Forgery (CSRF):** Trick users into performing unwanted actions.
- **Insecure Direct Object References (IDOR):** Accessing data without proper authorization.

  Visual: Infographic illustrating common vulnerabilities and their impacts.

Tools and Techniques for Web Security

- **OWASP Top 10:** A list of critical security risks for web applications.
- **Web Application Firewalls (WAF):** Protect against common attacks.
- **Regular Patching:** Fix vulnerabilities as soon as they're discovered.



Hands-On Activity Overview

Platform: TryHackMe

https://tryhackme.com/r/room/introwebapplicationsecurity

- **Room:** Web Fundamentals
- **Concepts Covered:** Identifying and exploiting vulnerabilities in web applications.
- **Steps:**
  1. Guided exploration of the first sections.
  2. Independent practice for 15-20 minutes.
  3. Discuss findings and challenges as a group.

  Visual: Screenshot of the TryHackMe Web Fundamentals room.

Penetration Testing Demo: IDOR & DOM-Based XSS in OWASP Juice Shop

- **What is OWASP Juice Shop?**
  - A deliberately vulnerable web application for ethical hacking practice.
  - Allows testing security flaws in a **legal and ethical** environment.
- **Demonstrating Two Vulnerabilities:**
  - **Insecure Direct Object References (IDOR)**
  - **DOM-Based Cross-Site Scripting (XSS)**
    - Example XSS payloads:
      <img src=x onerror=alert('DOM-XSS!')>
      <iframe src="javascript:alert('DOM-XSS Attack!')">
- **Why This Matters:**
  - Helps identify and fix vulnerabilities in real-world applications.
  - Juice Shop provides a safe space to **learn, experiment, and improve security skills**.

Debrief and Key Takeaways

- **Key Learnings:**
  - Common vulnerabilities and their real-world impact.
  - Strategies to defend against web application attacks.
- **Next Steps:**
  - Explore advanced web security concepts on TryHackMe.
  - Reflect on how secure coding practices can prevent vulnerabilities.

  Visual: Checklist or a group of students collaborating.

Q&A Session

CODE CRUNCH

Attendance

linktr.ee/CODE.CRUNCH

Join us for the next sessions

Thursdays: 11AM – 12PM & 2PM – 3PM
Friday: 3PM – 4PM
Monday: 12PM – 1PM

RSVP lu.ma/CODECRUNCH

Your feedback helps us improve. Share your thoughts!
Go to our website: go.fiu.edu/codecrunch